Data Protection & Retention Policy

Cosmaneura, Inc. — Cosma application

Version: 1.0 **Effective:** 2026-04-20 **Next review:** 2027-04-20 **Owner:** CTO / Data Protection Lead

1. Purpose

This policy describes what data Cosma collects on behalf of customers, how that data is classified and protected, how long it is retained, and what rights users have over it. It is the operational companion to the public Privacy Policy published at `cosmaneura.com`.

2. Data classification

Class	Examples	Baseline protection
Public	Marketing site content	Standard TLS
Internal	Application logs without PHI, product analytics	TLS + access control
Confidential	Customer account data, Zoom OAuth tokens, meeting metadata	TLS + access control + encryption at rest; OAuth tokens additionally encrypted at application layer (AES-128 / Fernet).
Restricted (PHI)	Meeting recordings, transcripts, clinical notes	Everything above, plus routing through the Azure Health De-identification API before any third-party large-language-model processing.

3. Categories of data processed

Category	Collected because	Processor(s)
Account identifiers (name, email)	Authentication & billing	Clerk, Cosma database
Zoom OAuth tokens	Required for the customer-authorized Zoom integration	Cosma database (AES-128 encrypted at rest)
Meeting metadata (ID, participants, schedule)	To display and orchestrate the meeting experience	Cosma database
Meeting audio recordings	To generate transcripts and clinical notes on behalf of the authorized user	Recall.ai (recording bot), Azure Blob Storage
Transcripts	Speech-to-text output used to produce notes	AssemblyAI, Cosma database, Azure Blob Storage

De-identified text sent to LLMs	Clinical note generation	Azure OpenAI (GPT-4.1); input is PHI-redacted by Azure Health De-ID beforehand
Product analytics events	To improve the product	PostHog
Error traces	Reliability & incident response	Sentry (PII scrubbing enabled)

4. Protected Health Information (PHI) handling

- PHI that could appear in transcripts is routed through the **Azure Health De-identification API** before any call to a large-language-model service.
- Access to raw (non-de-identified) recordings and transcripts is restricted to the authenticated end user who owns the data and to a minimal set of production operators acting under documented access-control procedures.
- Cosmaneura enters into a Business Associate Agreement (BAA) with any sub-processor that may handle PHI on the company's behalf, consistent with HIPAA Security Rule requirements.

5. Retention schedule

Data	Default retention	Trigger for deletion
Account data	Life of the account	Account deletion request, or 180 days after account termination.
Zoom OAuth tokens	Until revoked by the user or expired by Zoom	User-initiated disconnect, OAuth revoke, or account deletion.
Meeting metadata	Life of the account	Account deletion request, or 180 days after account termination.
Audio recordings (raw)	90 days after the meeting	Automatic purge job; earlier upon user request.
Transcripts	Life of the account	User-initiated deletion, or account deletion.
Clinical notes	Life of the account	User-initiated deletion, or account deletion.
Application & access logs	90 days	Automatic log rotation.
Sentry error traces	90 days	Sentry default retention.
Backups	30 days	Automatic rotation; deletions propagate within this window.

> Retention periods may be extended when required by law, by a signed customer contract, or by an active

> incident investigation. Customers on enterprise plans may negotiate custom retention windows.

6. Data subject rights

Upon verified request, users may:

- **Access** — receive a copy of the personal data Cosma holds about them.
- **Correct** — request correction of inaccurate personal data.
- **Delete** — request deletion of their account and associated data; deletion propagates to primary storage immediately and to backups within 30 days.
- **Export / portability** — receive a machine-readable export of their transcripts and notes.
- **Withdraw consent** — disconnect the Zoom integration at any time, which revokes stored OAuth tokens with Zoom.

Requests are submitted to `info@cosmaneura.com` and are actioned within 30 days.

7. Sub-processors & change notification

Cosma relies on the third-party processors listed in §3. A current list is maintained on the Cosmaneura website. Customers are notified by email of any material change to the sub-processor list at least 30 days before it takes effect, except where the change is required to address a security risk.

8. International transfers

Cosma's primary infrastructure is hosted in Microsoft Azure (US regions). Some sub-processors may process data outside the United States; in all such cases, the sub-processor commits to standard contractual clauses or equivalent transfer safeguards under applicable law.

9. Enforcement & review

Violations of this policy are investigated by the CTO and may result in disciplinary action up to and including termination. This policy is reviewed at least annually, or sooner if there is a material change in the data processed, the applicable law, or the sub-processor list.

10. Contact

Privacy requests: `info@cosmaneura.com` · Security: `dev@cosmaneura.com` · General: `info@cosmaneura.com`